
Die teuerste CA-Policy? Die auf Report-only vergessene.

Conditional Access: 3 Basis-Policies — und das Handwerk drumherum

Report-only richtig nutzen

☒ **Einführungsmodus**

Zeigt, was eine Policy blockieren würde — ohne jemanden auszusperrern.

☐ **Kein Betriebsmodus**

Sieht im Portal aus wie Schutz. Schützt nichts.

1

MFA für alle Benutzer

Nicht nur für Administratoren. Ausnahmen sind einzeln begründet — nicht historisch gewachsen.

Require multifactor authentication

2

Legacy-Auth blockieren

Alte Protokolle kennen kein MFA. Vorher in den Sign-in-Logs prüfen, was noch darüber läuft.

```
Block legacy authentication
```

3

Admin-Rollen verschärfen

Phishing-resistente MFA und verwaltete Geräte für alle privilegierten Rollen.

Require phishing-resistant MFA

Das Handwerk drumherum

- Break-Glass-Konten ausnehmen — und jede Anmeldung alarmieren
- Neue Policy: Report-only → prüfen → aktivieren. Mit Termin.
- Ohne Entra ID P1: Security Defaults aktivieren

**Selbstcheck: Report-only älter als 30 Tage?
Aktivieren oder löschen.**